

VPN Security Assessment - Technical Report

Capture: aes128-dh2-transport-pfs-off__web_run1.pcap | Generated: 2026-09-22 12:45 UTC | API schema 1.1

1. Result

Risk level	HIGH
Security score	30 / 100
Raw score / cap	30 from the known facts; capped at 62 by assessment completeness (41.7%). Rule: score <= 35 + 65 x completeness (LOW needs a score of at least 80, i.e. completeness of at least 69%)
Score basis	declared - cipher/DH/mode taken from the testbed naming convention in the capture file name, not observed in the capture
Traffic class (ML)	Web browsing (100.0% model confidence)

2. Score breakdown

Factor	Value	Rating	Source	Weight	Points	Contribution
Cipher	AES-CBC-128	medium	declared	0.4	60	30.0
AES-CBC-128 provides confidentiality only — it needs a separate HMAC for integrity, and mis-set integrity checking can open padding-oracle-style issues.						
DH group	Group 2 (1024-bit MODP)	weak	declared	0.4	0	0.0
1024-bit MODP is considered too small against modern computing power.						
PFS	unknown	unknown	unknown	0.2	-	-
Whether Perfect Forward Secrecy is enabled could not be determined from this capture.						
Mode	transport	medium	inferred	0.0	-	-
Transport mode leaves the original IP header visible; only the payload is encrypted.						
Integrity	separate HMAC, tag length 16 B or 32 B	medium	inferred	0.0	-	-
length mod 16 = 8 => ICV mod 16 = 0 (assumes AES-CBC with a 16-byte IV)						
Key lifetime	unknown	unknown	unknown	0.0	-	-

not observable in this capture (no rekey - a new SPI in the same direction - was seen)						
Replay protection	sender uses a strictly increasing sequence counter	medium	inferred	0.0	-	-
all 2 SA(s) with enough packets use a strictly increasing sequence counter (no duplicates, no out-of-order packets, 0 sequence numbers never seen)						

Points: strong = 100, medium = 60, weak = 0. Score = $\text{sum}(\text{points} \times \text{weight}) / \text{sum}(\text{weights of rated factors})$, rounded. Unknown factors and Mode (weight 0) are excluded. Risk: score ≥ 80 LOW, ≥ 50 MEDIUM, otherwise HIGH.

2b. Findings and their status

Every finding is tagged: observed = read from the capture; inferred = deduced from packet sizes or sequence numbers (with a confidence, never from file names); declared = stated by the testbed file name (unverified); unknown = not determinable from this capture.

Finding	Value	Status	Confidence	Evidence
IKE version	unknown	unknown	-	no IKE_SA_INIT in this capture (encrypted IKE messages only, or none)
IPsec protocol (ESP / AH)	ESP	observed	100%	300 ESP packets seen
Tunnel or transport mode	transport	inferred	100%	learned from packet-size statistics (tunnel mode adds an inner IP header to every packet); trained on scripted lab traffic
Cipher (algorithm / family)	AES-CBC-128	declared	-	from the testbed file name (unverified)
Key length	128 bits	declared	-	from the testbed file name (unverified)
Integrity protection	separate HMAC, tag length 16 B or 32 B	inferred	50%	$\text{length mod } 16 = 8 \Rightarrow \text{ICV mod } 16 = 0$ (assumes AES-CBC with a 16-byte IV)
Key exchange (DH group)	Group 2 (1024-bit MODP)	declared	-	from the testbed file name (unverified)

Perfect Forward Secrecy	unknown	unknown	-	negotiated inside encrypted IKE messages; not observable passively
Authentication method	unknown	unknown	-	pre-shared key vs certificate is negotiated in the encrypted IKE_AUTH exchange; not observable passively
SA / key lifetime	unknown	unknown	-	not observable in this capture (no rekey - a new SPI in the same direction - was seen)
Replay protection	sender uses a strictly increasing sequence counter	inferred	60%	all 2 SA(s) with enough packets use a strictly increasing sequence counter (no duplicates, no out-of-order packets, 0 sequence numbers never seen)

3. IKE handshake analysis

IKE version observed	unknown
IKE_SA_INIT captured	no
IKE packets (encrypted / total)	0 / 0
ESP packets seen	300
SA source	none
IKE SA	not observed
Mode observed	unknown
Truncated	no

Only IKE_SA_INIT is sent in clear. The child (ESP) SA, PFS and tunnel/transport mode are negotiated inside the encrypted IKE_AUTH / CREATE_CHILD_SA exchanges (RFC 7296) and cannot be read from a passive capture.

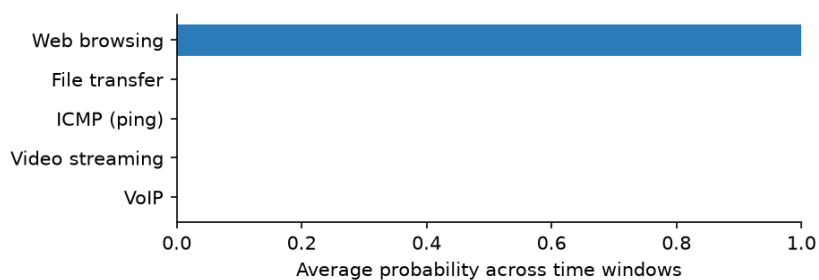
4. Capture summary

Packets analysed	300 (ESP only)
Bytes	59760
Time span	19.376 s
Time windows	20 x 1.0 s (0 dropped: fewer than 2 packets)

5. Traffic classification

Random Forest on 12 fixed-window features of the ESP packets (sizes, rates, inter-arrival times, direction). The capture-level class is the class with the highest mean probability over all windows.

Class	Mean probability
Web browsing	100.0%
File transfer	0.0%
ICMP (ping)	0.0%
Video streaming	0.0%
VoIP	0.0%

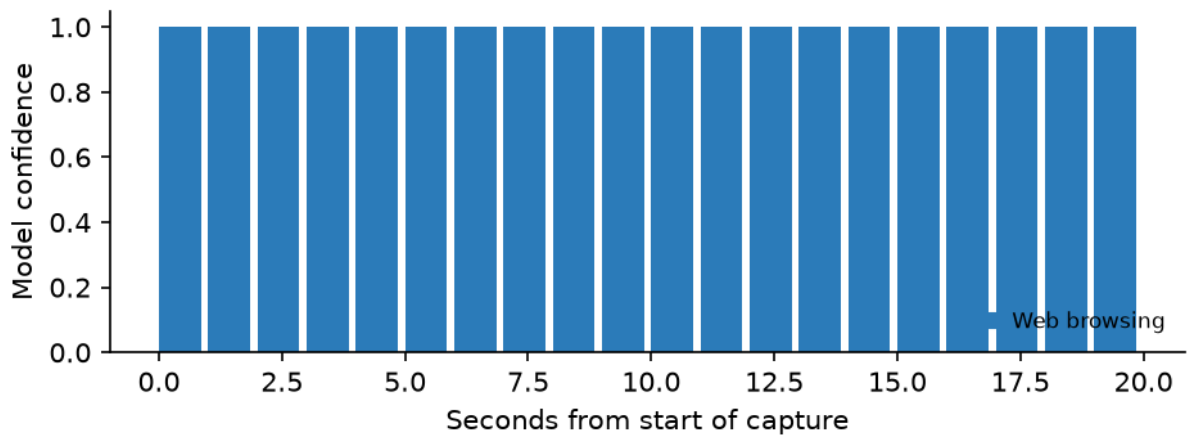


Why (SHAP)

Average SHAP contribution of each feature towards the predicted class over the analysed windows.

- Data rate (bytes per second) (typically 1992) pushed the prediction towards 'web browsing'.
- Average packet size (typically 199.2) pushed the prediction towards 'web browsing'.
- Share of packets sent in the first direction (typically 0.6) pushed the prediction towards 'web browsing'.

6. Timeline (fixed 1.0 s windows)



Window	Time	Class	Confidence	Packets	Bytes
1	0.0-1.0 s	Web browsing	100.0%	30	5976
2	1.0-2.0 s	Web browsing	100.0%	10	1992
3	2.0-3.0 s	Web browsing	100.0%	20	3984
4	3.0-4.0 s	Web browsing	100.0%	10	1992
5	4.0-5.0 s	Web browsing	100.0%	20	3984
6	5.0-6.0 s	Web browsing	100.0%	10	1992
7	6.0-7.0 s	Web browsing	100.0%	20	3984
8	7.0-8.0 s	Web browsing	100.0%	10	1992
9	8.0-9.0 s	Web browsing	100.0%	20	3984
10	9.0-10.0 s	Web browsing	100.0%	10	1992
11	10.0-11.0 s	Web browsing	100.0%	10	1992
12	11.0-12.0 s	Web browsing	100.0%	10	1992
13	12.0-13.0 s	Web browsing	100.0%	10	1992
14	13.0-14.0 s	Web browsing	100.0%	20	3984
15	14.0-15.0 s	Web browsing	100.0%	20	3984
16	15.0-16.0 s	Web browsing	100.0%	20	3984
17	16.0-17.0 s	Web browsing	100.0%	20	3984
18	17.0-18.0 s	Web browsing	100.0%	10	1992

19	18.0-19.0 s	Web browsing	100.0%	10	1992
20	19.0-20.0 s	Web browsing	100.0%	10	1992

7. Anomalies

No anomaly rule fired.

8. Notes and warnings

- No IKE_SA_INIT exchange was found in this pcap, so cipher and DH group cannot be read from it (it may contain only ESP data).
- Tunnel/transport mode is negotiated inside the encrypted IKE_AUTH exchange and is not observable in this capture; it is reported as 'unknown'.
- The ESP SA's own cipher/DH/PFS live inside the encrypted IKE_AUTH exchange and were not observed; PFS is reported as unknown.

8b. Metadata exposure (what an eavesdropper learns)

Exposure score **99 / 100 (HIGH)** - 0 = an eavesdropper learns nothing, 100 = learns everything listed.

What	Points	What is learned
Traffic type	30.0 / 30	Web browsing (model confidence 100%). packet sizes and timing reveal what the tunnel is used for, even though the payload is encrypted.
Tunnel vs transport mode	10.0 / 10	transport. extra inner IP header changes every packet size.
Cipher family	9.4 / 10	CBC-like (16-byte block aligned). padding granularity (CBC vs AEAD) shows in the packet lengths.
Packet-size distribution	15.0 / 15	always visible. ESP does not hide packet lengths unless padding is added.
Timing and volume	20.0 / 20	always visible. packet times and byte counts are visible on the wire.
Communicating endpoints	15.0 / 15	the actual hosts. outer IP addresses are always in clear; tunnel mode hides the real endpoints behind the gateways.

8c. Guideline mapping

Guideline mapping against published guidance - NOT a certification or audit result

Guideline	Requirement	Result	Evidence
NIST SP 800-131A Rev. 2	Three-key TDEA (3DES) is not acceptable for encryption after 2023	meets	cipher is AES-CBC (declared)
NIST FIPS 197 / SP 800-38	Use an approved block cipher (AES) and mode	meets	cipher is AES-CBC (declared)
NIST SP 800-131A Rev. 2 / SP 800-57	Key establishment with at least 112 bits of security strength (finite-field DH of at least 2048 bits)	does not meet	Group 2 (1024-bit MODP) is below 2048 bits (declared)
RFC 8221	ESP encryption algorithm is one of the mandatory-to-implement AES-CBC or AES-GCM-16	meets	cipher is AES-CBC (declared)
RFC 8247	IKEv2 MODP group 14 (2048-bit) is a mandatory-to-implement group	cannot assess	only evaluated when group 14 is the negotiated group (declared)

- NIST SP 800-77 Rev. 1 (Guide to IPsec VPNs): used as general background only; no individual requirement is encoded here.
- RFC 8247 is encoded for one item only (IKEv2 group 14); other group requirement levels are not evaluated.
- FIPS 140 module validation, key management, authentication strength and certificate policy are outside what a capture can show.

8d. Recommendations and secure configuration

#	Priority	Action	Why	Based on
1	High	Replace the weak Diffie-Hellman group. Change the key-exchange group from Group 2 (1024-bit MODP) to an elliptic-curve group (19 or 20) or MODP 3072-bit or larger.	Groups below 2048 bits give less than 112 bits of security strength.	declared

2	Medium	Prefer an AEAD cipher (AES-256-GCM) over AES-CBC. Use aes256gcm16 for IKE and ESP: it protects integrity and confidentiality in one step and needs no separate HMAC.	Removes padding-oracle style risks of CBC + HMAC and gives a 256-bit key.	declared
3	Medium	Verify that Perfect Forward Secrecy is enabled. PFS is negotiated inside encrypted IKE messages and cannot be seen in a capture. Confirm the ESP proposal contains a DH group (for strongSwan: esp=...-ecp384!) with `ipsec statusall`.	It carries 15% of the assessment.	unknown
4	Medium	Capture from before the tunnel comes up. Start the capture, then bring the tunnel up (for example `tcpdump -w` first, then `ipsec up`), so IKE_SA_INIT is included.	It is the only place the cipher and DH group are visible; without it the assessment stays incomplete.	unknown

5	Medium	Reduce the traffic-type leak. An eavesdropper can tell this traffic is web browsing (100%). Padding packets to fixed sizes and adding dummy traffic reduces this; see the defence simulation for the effect measured on this project's dataset.	IPsec encrypts payloads but not packet sizes or timing.	inferred
6	Low	Use tunnel mode unless host-to-host transport mode is required. Tunnel mode encrypts the original IP header and hides the real endpoints behind the gateways.	Reduces what an eavesdropper learns about who talks to whom.	inferred
7	Low	Set and verify a short SA lifetime. Set keylife=1h and ikelifetime=4h, then verify with a capture at least twice as long as keylife so a rekey is observed.	The lifetime cannot be observed unless a rekey happens inside the capture.	unknown

Standard strongSwan syntax, but NOT verified against a running strongSwan in this project (Docker was unavailable).
Test it in a lab first; replace every <placeholder>.

```
# Generated by the IPsec VPN Analyzer - a starting point, NOT a tested production config.
# Replace the <placeholders>, then test in a lab (ipsec statusall, tcpdump) before using it.
config setup
    charondebug="ike 1, esp 1"

conn secure-vpn
    keyexchange=ikev2
    left=<THIS_GATEWAY_IP>
    right=<PEER_GATEWAY_IP>
    type=tunnel
    authby=pubkey                # certificates; if you must use a pre-shared key: authby=secret with 20+ r
    leftcert=<THIS_GATEWAY_CERT>
    ike=aes256gcm16-prfsha384-ecp384!                # AES-256-GCM, SHA-384 PRF, ECP-384 (group 20)
    esp=aes256gcm16-ecp384!                # AES-256-GCM; the ecp384 group here enables Perfect Forward Secrecy
    ikelifetime=4h
    keylife=1h
```

```
rekeymargin=9m
dpdaction=restart
dpddelay=30s
auto=start
```

Before / after (Projection - what the tool would report if the recommended configuration were applied (not a measurement)): before 30; after a new passive capture 80 (completeness 69.0%); after a direct configuration review 100.

8e. Defence what-if (SIMULATION)

SIMULATION. SIMULATION - the packets of this capture were rewritten at the feature level; nothing was re-sent and no gateway was configured. The classifier shown is the one trained on clean traffic (a non-adaptive attacker).

Without a defence the classifier says **web_browsing** (100%).

Defence	Classifier then says	Bandwidth	Delay
Pad packets to size buckets every packet padded up to the next of (128, 256, 512, 1024, 1500) bytes	web_browsing (100%)	+15.7%	0.0 ms
Pad every packet to full size every packet padded to 1500 bytes	unrecognised (48%) - changed	+653.0%	0.0 ms
Constant-rate dummy traffic 40 dummy packets per second of 600 bytes	unrecognised (41%) - changed	+778.1%	0.0 ms
Random delay (timing jitter) each packet delayed by $ N(0, 100 \text{ ms}) $	unrecognised (96%) - changed	+0.0%	83.2 ms
Timing shaping packets held until the next 100 ms slot	unrecognised (94%) - changed	+0.0%	55.7 ms
Combined size buckets + dummy traffic + random delay	unrecognised (43%) - changed	+793.8%	78.6 ms

Across the 180 lab captures (unseen VPN configurations). Naive attacker = classifier trained on clean traffic; adaptive attacker = retrained on defended traffic. Chance level 20%.

Defence	Naive attacker	Adaptive attacker	Median bandwidth
No defence	100.0%	-	0%

Pad packets to size buckets	100.0%	100.0%	+10.2%
Pad every packet to full size	42.8%	100.0%	+223.4%
Constant-rate dummy traffic	60.0%	100.0%	+71.9%
Random delay (timing jitter)	99.4%	100.0%	+0.0%
Timing shaping	100.0%	100.0%	+0.0%
Combined	60.0%	100.0%	+119.2%

- Feature-level simulation on scripted lab traffic: real padding/dummy-traffic implementations differ in detail.
- The adaptive attacker uses the same 12 window features; a stronger attacker (sequence models, longer windows) may do better.
- Captures are short (file transfer, VoIP and video < 2 s), which limits how well dummy traffic and shaping can be judged.
- Costs are per capture and depend on how busy the capture is: padding a ping stream costs a lot, padding a bulk transfer almost nothing.

9. Model validation and limits

Model	random_forest, 12 features, 1.0 s windows
Training data	180 captures, 1027 windows, 36 VPN configurations
Evaluation	StratifiedGroupKFold(n_splits=6), grouped by VPN config, seed 42; out-of-fold predictions
Accuracy on unseen VPN configs	window level 100.0%, capture level 100.0%
Sanity: label-shuffled accuracy	46.2% (below the 59.5% majority-class baseline: with shuffled labels the model cannot beat guessing, so the real result is not a pipeline artefact)

- One capture per (config, class): 36 configs x 5 classes, generated by scripted tools in a Docker testbed.
- Generators are synthetic (ping, scp, curl loops, ffmpeg range requests, SIPp signalling only, no RTP).
- Captures were stopped by packet count, so file_transfer/voip/video are <2 s long: they yield 1-2 windows each.
- Results say how well the model separates THESE five scripted traffic types on unseen VPN configs, not how it would do on real user traffic.